



Data Protection Education
Unit 1, Saltmore Farm
Hinxworth
Hertfordshire
SG7 5EZ

17 March 2019

DPE response to NCC General Data Protection Regulation (GDPR) – Schools Audits: Summer 2019

Following the report from NCC, there were several recommendations made and I want to comment on these individually, as well as provide some perspective on our approach to compliance and data risk mitigation.

Broadly, there are two elements relating to GDPR compliance:

1. Protection of data, adherence to the data protection principles and the respect of data subjects rights (the practicalities of GDPR operations)
2. Documentation of activity related to no.1

Whilst we do not underestimate the documentation activity (GDPR has approximately 50 areas where documentation relating to compliance is required), GDPR compliance is not possible in all areas without considerable time and effort.

Therefore our approach with SLAs totalling only a few days across the year, that the highest priorities have been the mitigation of identifiable risk related to GDPR operations. We know that there have been enforcement actions in this area and none that we are aware of in relation to documentation, other than those related to the principle of transparency - i.e. privacy notices.

We haven't neglected documentation - our commitment to compliance toolkit included the documents and tools related to ensuring baseline compliance. Elizabeth Denham, the information commissioner at the Data Protection Practitioner's Conference this year, acknowledged that many organisations had spent the first year of GDPR reaching this baseline, but that there was more to do.

We agree this must be done and we have no intention of ignoring the documentation requirements - in fact, our efforts in building the Knowledge Bank with its best practice library, compliance and reporting tools have been made (and continue to be to ensure that we have documentation to support GPDR monitoring, reporting and assessment to the International Standard ISO 27701. But this is a long-term project even with more time/budget allocated and we have chosen carefully the priorities that best protect the rights of data subjects and minimise your exposure to enforcement actions.

I'd like to address the specific outstanding issues from the NCC report:

1. **The Information Commissioner's Office (ICO) had not been provided with details of who the designated DPO was at the School.**

We have issued this advice in newsletters and on the Knowledge Bank that schools are responsible to ensure this information is added with the ICO, and how to do it. The reason being that if we cease being your DPO, it is equally important that you update the information.

To ensure that this issue is resolved, we are introducing this as an agenda item on all school visits and remote sessions. We will also add the relevant information again in our September newsletter.

2. **An information audit, or similar exercise, documenting and considering all personal data that is processed and held at the School, had not been completed. It is understood that the external DPO recommended waiting for the introduction of a new data processing tool, due to be launched in September 2019, which would assist in mapping data.**

Our approach in year one visits has been to assess and provide reports on the more immediate data protection risks. However, all schools were provided with our toolkit with the Information Commissioner's Office spreadsheet to document data processes. Additionally, many Norfolk schools bought-in (at the advice of NCC) GDPRiS a tool designed to provide data mapping.

The reports from our visits have in many cases identified and provided remedial suggestions for many processing risks. This has been a higher priority than a full data inventory.

Other considerations are the time, effort and difficulty of completing the ICO spreadsheet (based on our customer feedback), and then the question of what do you do with this data once the spreadsheet has been completed.

We completely agree that this needs to be done (GDPR Article 30), as it is an important step in the GDPR document process (and why it was issued in our initial toolkit). However, it has been a lower priority than addressing visible data risks, training, and other material risks. We base our priorities on what can be delivered within our SLA and the potential risk to you of enforcement actions.

Our response has been to invest heavily into our own technology platform that provides many benefits to you, not just as a compliance tick-box activity and within your Data Protection Education SLA. This has taken several months to design, build, test and populate with content (which is ongoing).

Our Record of Processing (RoP) tool will add value and save time in various ways:

- By providing a list of generic processes to select and adapt, rather than each school starting from a blank canvas
- Creating documents such as privacy notices and retention schedules directly from the RoP
- Providing individual roles with a proficiency assessment of required data protection skills for the processes with which they are involved
- Allowing detailed risk assessments for identified processes
- Comparing your process efficiency and risk against other schools similar processes (with the aim of identifying areas of improvement with real data)
- A centralised and managed record of GDPR compliance against each process

Our plan was to roll this part of the Knowledge Bank out in the 2019-20 school year and our phase one release is now available on the Knowledge Bank. We published an introduction to the RoP tool on our blog in June:

<https://kb.dataprotection.education/news-top/news/94-siteupdates/108-record-of-processing-tool-preview>

We believe that the RoP tool is one of the most comprehensive of its kind available in the market today, even in corporate systems costing tens of thousands of pounds. It has been a huge investment for us on your behalf and will form a key piece in our support to you as DPO. It is a complex tool and we have always envisaged that we will support you on its use.

We want to move up the wisdom hierarchy, from data in a spreadsheet to information in our platform that gives us practical knowledge about what we do and wisdom through data-driven decision making about your documented processes. It's not an instant process, but we believe will provide considerable benefits to you over time.

3. The lawful basis for which all data is processed and held at the School had not been identified.

This will be documented within the RoP for each and every process. Though not explicitly documented at present we are always cognisant of the relevant lawful bases for processing, especially where these have changed under GDPR, especially around the use and documentation of consent, where incorrect use has already seen enforcement action under GDPR.

We have advised (and will continue to do so) on how consent is used (and how it should not be used) as well as (though less so) on the other lawful bases - always with the intent to follow up with accurate documentation. Incorrect use of consent in the first year of GDPR has been far more likely to result in an enforcement action than non-documentation of the lawful basis.

4. No checks had been carried out to ascertain the reasons why third party suppliers hold and process the School's data, and whether these reasons were lawful.

This is a slightly confusing statement. The lawful basis of why a third-party supplier processes data is based always on the explicit instructions in a contract or data-sharing agreement; there is no other lawful basis. (In GDPR, this is under Article 28 that looks at Controller-to-Processor relationships. The lawful bases (in Article 6, for example, consent) relate only to Controller-to-Data Subject relationships).

Since the launch of GDPR, we have consistently informed our customers to ensure (as per the guidance of the Information Commissioner's Office) that contracts with suppliers should be GDPR compliant (i.e include data sharing provisions) and to ask for updated information if not. This was explicit in our GDPR toolkit issued to all schools.

The management of all aspects of a contract (not just the data protection clauses) is an important issue for any party to that contract. We have always been available to advise on specific contracts and have done so many times.

As we move on the Knowledge Bank to the documentation of GDPR activity, we have added the ability to assess and document third-party compliance into the RoP tool.

To resolve this issue, some remote sessions within your SLA will focus on ensuring this specific area is reviewed. This will require support from each organisation but we will develop guidance to help understand and document the requirements appropriately.

5. **The process for the completion of Data Protection Impact Assessments (DPIA) is not documented and staff have not been subject to any training around how to complete a DPIA or to ensure they understand the need to consider a DPIA at the early stages of any plan involving personal data.**
6. **It was noted that the required staff at these schools do have an awareness of when a DPIA would need completing.**

DPIAs are part of the role of the Data Protection Officer (Article 35 of the GDPR) and we have undertaken many both upon request from our customers and at our insistence where we are aware that they are needed. They are described in our model Data Protection Policy document. You can conduct them yourselves, but we should be involved (GDPR Article 35)

The RoP tool has a specific section to conduct and document risk assessments for each and every process. In almost all cases, this covers the level of detail required for a DPIA. In special circumstances (e.g. use of CCTV) we sometimes use the Surveillance Camera Commissioner's DPIA template as this is focussed on the use of cameras. This can be attached to the relevant RoP record.

DPIAs are time and resource intensive so we choose the high-risk processes from our visits and consultations. We look for those areas where it may be appropriate to undertake one where we consider that the current processing places undue risk on the rights of data subjects. Having predefined risks (that can be adapted to circumstances) on the RoP will massively reduce the time and effort in defining, documenting and most importantly, mitigating risk.

However, we completely understand the issue of awareness. We are currently working on additional support materials relating to recognition and response of both subject access requests and data breaches. We will immediately follow up on these areas with a dedicated area and content on the Knowledge Bank on DPIAs and risk assessment, including compliance and corporate governance risk as well as day-to-day operation risk.

In summary, our aim has been and remains to best utilise the time available in our SLA whilst minimising disruption to our customers and at the same time strengthening data protection and the rights of data subjects in each organisation. People are often cited as one of the greatest risks, so we have focussed on training and cultural change to embed data protection in everyday operations.

We are always open to suggestions and welcome your feedback, but GDPR compliance does not have a single quick fix - it impacts on each and every area of data handling in your organisation.

Elizabeth Denham, the Information Commissioner had this to say in her blog “GDPR: One Year On”:

“The focus for the second year of the GDPR must be beyond baseline compliance - organisations need to shift their focus to accountability with a real evidenced understanding of the risks to individuals in the way they process data and how those risks should be mitigated. Well-supported and resourced DPOs are central to effective accountability.”

<https://ico.org.uk/about-the-ico/news-and-events/news-and-blogs/2019/05/gdpr-one-year-on/>



That is our aim and has always been our approach - get to baseline compliance as soon as possible and push onto the evidenced understanding that leads to improvements and efficiency.

I hope this addresses any concerns - if not, I am happy to make myself available for a Governor's meeting to report on any aspect of our programme and how it relates to your organisation.

Sincerely,

James England

James England
Director, Data Protection Education Ltd